

Learning-based Models for Vulnerability Detection: An Extensive Study

Chao Ni*
School of Software Technology,
Zhejiang University
Hangzhou, Zhejiang, China
chaoni@zju.edu.cn

Liyu Shen
School of Software Technology,
Zhejiang University
Hangzhou, China
liyushen@zju.edu.cn

Xiaodan Xu
Zhejiang University
Hangzhou, China
xiaodanxu@zju.edu.cn

Xin Yin
School of Software Technology,
Zhejiang University
Hangzhou, China
xyin@zju.edu.cn

Shaohua Wang
Central University of Finance and
Economics
Beijing, China
davidshwang@ieee.org

ABSTRACT

Though many deep learning-based models have made great progress in vulnerability detection, we have no good understanding of these models, which limits the further advancement of model capability, understanding of the mechanism of model detection, and efficiency and safety of practical application of models. In this paper, we extensively and comprehensively investigate two types of state-of-the-art learning-based approaches (sequence-based and graph-based) by conducting experiments on a recently built large-scale dataset. We investigate seven research questions from five dimensions, namely *model capabilities*, *model interpretation*, *model stability*, *ease of use of model*, and *model economy*. We experimentally demonstrate the priority of sequence-based models and the limited abilities of both LLM (ChatGPT) and graph-based models. We explore the types of vulnerability that learning-based models skilled in and reveal the instability of the models though the input is subtly semantical-equivalently changed. We empirically explain what the models have learned. We summarize the pre-processing as well as requirements for easily using the models. Finally, we initially induce the vital information for economically and safely practical usage of these models.

CCS CONCEPTS

• **Software and its engineering** → **Software defect analysis**.

KEYWORDS

Vulnerability Detection, Empirical Study, Large Language Model

*Chao Ni is the corresponding author.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than ACM must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

Conference'17, July 2017, Washington, DC, USA

© 2024 Association for Computing Machinery.

ACM ISBN 978-x-xxxx-xxxx-x/YY/MM...\$15.00

<https://doi.org/XXXXXXX.XXXXXXX>

ACM Reference Format:

Chao Ni, Liyu Shen, Xiaodan Xu, Xin Yin, and Shaohua Wang. 2024. Learning-based Models for Vulnerability Detection: An Extensive Study. In *Proceedings of ACM Conference (Conference'17)*. ACM, New York, NY, USA, 13 pages. <https://doi.org/XXXXXXX.XXXXXXX>

1 INTRODUCTION

Automated vulnerability detection is a fundamental problem in system security and learning-based vulnerability detection approaches have achieved promising results in recent years. Notably, several research has demonstrated that deep learning (DL)-based approaches can achieve both high accuracy (up to 95%) [25, 28, 29, 36, 44, 49, 63] and high F1-score (up to 90%) [20, 47] at detecting vulnerabilities.

Despite the remarkable success of DL models at detecting vulnerabilities, we seem to know little about the models themselves. For example, whether they can be used effectively and reliably in detecting real-world or most dangerous vulnerabilities, what kind of vulnerability the models are skilled in detecting, what kind of features these models have learned, whether the models can stably perform on semantically equal functions, what is the complexity and what is the cost if we want to use DL models, whether it will damage our privacy. Figuring out the answers to these questions can help us better develop and apply the models in practical usage, especially in the era of large language models.

Some work [12, 48] also aim at investigating the characteristics or capabilities of deep learning-based models, but there still are a few limitations in guiding practice use. For example, (1) The conclusions obtained by different works may be inconsistent. Some works [56, 58] conclude that graph-based DL models outperform sequence-based models, while some works [20, 41] achieve the opposite observation. (2) Existing studies only include graph-based or sequence-based models, but the current eye-catching large language model (e.g., ChatGPT [2]) has not been comprehensively studied, which may cause the conclusion to be biased. (3) Previous studies only consider the capability and explanation of DL models but do not consider the impacts on users: ease of use of the model and cost of using the model.

In this paper, we systematically and comprehensively investigate the characteristics of several SOTA deep learning-based vulnerability detection [12, 20, 26, 41, 63] and construct research questions to understand these models with the goal of distilling lessons and guidelines for better practical usage. We primarily focus on the graph-based and sequence-based vulnerability detection models at function granularity. To the best of our knowledge, this is the first paper that systematically investigates SOTA learning-based models across a wide range of aspects in the era of LLMs.

In particular, we conduct seven research questions and classify them into the following dimensions: **D1: model capabilities**, **D2: model interpretation**, **D3: model stability**, **D4: ease of use of model** and **D5: model economy**. More precisely, our first goal is to understand the capabilities of the learning models for vulnerability detection tasks, especially aiming at asking the following research questions:

- **RQ-1:** How do learning-based approaches perform on vulnerability detection? What are the variabilities across different models?
- **RQ-2:** What types of vulnerabilities are learning-based approaches skilled in detecting?
- **RQ-3:** Are Large Language Models capable of detecting vulnerabilities?

Our second study aims at the model interpretation. We adopt the state-of-the-art explanation tools to investigate what the model has learned as follows:

- **RQ-4:** What source code information does the learning-based model focus on? Do different types of learning-based models agree on similar important code features?

Our third study targets the stability of the studied learning-based models by investigating the impacts of semantically equivalent subtle modifications to their input.

- **RQ-5:** Do learning-based models agree on the vulnerability detection results with themselves when the input is insignificantly changed?

Our fourth study focuses on the ease of use by investigating the various efforts to build an effective model.

- **RQ-6:** What types of efforts should be paid before using a model? In what scenarios can learning-based models be applied?

Finally, our study focuses on the economy. We want to investigate the cost when adopting the models to detect vulnerability.

- **RQ-7:** What are the costs caused by models from both time and economic aspects?

To answer the aforementioned research questions, we investigate two types of state-of-the-art learning-based models. These models used different deep learning architectures (e.g., transformer [53] or graph [62]). Besides, to extensively and comprehensively analyze the models' ability, we conduct experiments on the recently built dataset named MegaVul [38], which contains real-world projects' vulnerabilities by crawling more newly discovered vulnerabilities. Then, we carefully design experiments to discover the findings by answering seven RQs. Eventually, the main contribution of our work is summarized as follows and takeaway findings are shown in Table 1.

- We conduct an extensive comparison among learning-based approaches on vulnerability detection including ChatGPT.
- We design seven RQs grouped into five important dimensions to understand learning-based approaches comprehensively.
- We release our reproduction package for further study [7].

2 EXPERIMENTAL SETUP

In this section, we first introduce our studied dataset. Following that, we briefly describe the studied learning-based models and evaluation metrics. Finally, the implementation details are presented.

2.1 Studied Dataset

Though many vulnerability-related datasets have been proposed, there are still some limitations that impact the verification of proposed models, including (1) *unreal vulnerability* (i.e., SARD [1] is artificially synthesized), (2) *unreal data distribution* (i.e., balanced distribution in Devign [63]), (3) *limited diversity* (i.e., limited projects and vulnerability types in ReVeal [12]), (4) *limited newly disclosed vulnerabilities* (i.e., no updated to Big-Vul [17] covering the period only from 2003 to 2019), and (5) *low-quality of dataset* (i.e., incomplete function, erroneously merged functions, missed commit message in Big-Vul [17]).

To address the issues above, recently, Ni et al. [38] built a large-scale, high-quality, data-rich, multi-dimensional C/C++ and Java dataset named MegaVul by crawling data from more open-source repositories, adopting sophisticated filtering strategies to improve the quality, and employing advanced techniques to extract complete functions. In addition to collecting the raw functions, MegaVul also provides more dimension information on the function, including the nine types of granularity abstraction of functions (i.e., *FUNC*, *VAR*, *STRING*, etc.), various types of function representations (i.e., *AST*, *PDG*), and the details of function modifications (i.e., *diff*). In summary, MegaVul collects 17 Git-based code hosting platforms from 349 websites that had referenced the CVEs more than 100 times. The web-based code hosting platforms can be categorized into five main categories: GitHub, GitLab, GitWeb, CGit, and Gitiles. Considering both the regular updates (i.e., update every six months) and the stability of MegaVul, we consider the C/C++ dataset released in October 2023 for experiments. That is, for the C/C++ version, MegaVul contains 8,334 commits from 198,994 CVEs. Table 2 presents the statistical information of MegaVul and more details can be referred to their original work [38].

2.2 Studied Baselines and Evaluation Metrics

Baselines. To comprehensively compare the performance of existing work, in this paper, we consider the five state-of-the-art learning-based software vulnerability detection approaches and these approaches can be further divided into two finer categories: graph-based ones and sequence-based ones. The former group contains three methods (i.e., Devign [63], ReVeal [12] and IVDETECT [26]) and they transform source code into a graph to complexly represent its semantic. The latter group contains two approaches (i.e., LineVul [20] and SVuLD [41]) and they treat the source code as the sequence of tokens to simply represent its semantic. Here, we briefly introduce these methods to make our paper self-contained.

Table 1: Insights and Takeaways: Evaluation on Extensive Newly Built Dataset (MegaVul)

Dimension	Findings or Insights
Capability	①. Sequence-based models outperform graph-based models. ②. ChatGPT is not yet competent for vulnerability detection and different prompts enable varying ability. ③. Different models have their own advantages in detecting different types of vulnerabilities. ④. Sequence-based models are skilled in "Input Validation". ⑤. Graph-based models are skilled in "API Abuse", "Input Validation" and "Security Features". ⑥. Sequence-based models especially SVulD its promising potential in practical usage.
Interpretation	⑦. Both graph-based and sequence-based methods focus on two types of statements: "Function Calls" and "Field Expressions". ⑧. Learning-based models still have a limited ability to distinguish vulnerable functions from non-vulnerable functions. ⑨. Feeding external called function information sequence-based method could further improve sequence-based models' ability.
Stability	⑩. All the learning-based models are unstable to input changes even if these changes are semantically equivalent. ⑪. Sequence-based models perform more stably than graph-based models.
Ease of Use	⑫. Sequence-based models: easy to deploy, limited input size, fine-tuning, open-source, privacy-safe. - ChatGPT: easy to use, larger input size; privacy-unsafe. ⑬. Graph-based models: complete function, complex configurations, limited input size, fine-tuning, open-source, privacy-safe.
Economy	⑭. Graph-based models need large amounts of time for data preprocessing, but they typically train and infer fast. - Sequence-based models do not involve data preprocessing, with a comparable training time and longer inference time. ⑮. ChatGPT is the most economical solution.

Evaluation Metrics. To comprehensively investigate the performance of learning-based models for vulnerability detection, we adopt the following widely used evaluation metrics [20, 39, 41, 63]: Accuracy(A), Precision(P), Recall(R), and F1-score(F1).

Table 2: The statistics of MegaVul (C/C++)

Attributes	MegaVul
Number of Projects	736
Number of CVE IDs	5,714
Date range of crawled CVEs	2013/01~2023/04 (continuously updating)
Number of CWE IDs	159
Number of Commits	6,437
Number of Crawled Code Hosting Platforms	17
Number of Vul/Non-Vul Function	14,216/377,185
Function Extract Strategy	Tree-sitter
Dimensions of Information	6
Code Availability	Full

2.3 Implementation Details

Data Splitting. Similar to existing work [20, 26], we adopt the same data splitting approach: 80%:10%:10%. More precisely, the whole dataset is split into 80% of training data, 10% of validation data, and 10% of testing data. Meanwhile, we also keep the class distribution as same as the original ones in training data, validation data, and testing data.

Model Implementation. Regarding ReVeal, IVDetect, LineVul, and SVulD, we utilize their publicly available source code and perform fine-tuning with the default parameters provided in their original code. Considering Devign's code is not publicly available, we make every effort to replicate its functionality and achieve similar results on the original paper's dataset. All these models are implemented using the PyTorch [43] framework by fully adopting the pre-trained models hosted on Huggingface [5]. Additionally, we incorporate

interpretability into all studied models. The fine-tuning process is performed on NVIDIA RTX 3090 graphics card. For the LLMs, we use the state-of-the-art ChatGPT [42] model and set the number of few-shot learning examples between 1 and 6 to fill the context window (i.e. 4,096 tokens). We also instruct ChatGPT to output the results in JSON format to facilitate the automatic organization of the data.

3 RESEARCH QUESTION AND FINDINGS

In this section, we divide our seven research questions into five dimensions: *D1: model capabilities*, *D2: model interpretation*, *D3: model stability*, *ease of use of model* and *model economy*. For each RQ, we introduce the objective, the experimental setup, the results, and our findings.

3.1 D1: Capabilities of Learning-based Models for Vulnerability Detection

•[RQ-1]: How do learning-based approaches perform on vulnerability detection? What are the variabilities across different models?

Objective. Many deep learning-based vulnerability detection approaches have been proposed [11, 22, 26, 29, 41, 56, 63] and they mainly focus on function-level vulnerability detection, treating the source code in different ways. That is, some approaches [26, 63] consider the complex structure inside a function and transform it into a graph, while some approaches [20, 41] simply treat it as a sequence of tokens without considering its structure (i.e., sequence-based). Though these methods have been well compared in previous studies [41, 48, 56], their experiments are usually conducted on a limited or small-scale dataset, which may impact the consistency of models' capabilities. For example, Wen et al. [58] concluded that a complex graph-based model embedding a function by considering the program structure can yield better performance than sequence-based

models. However, according to recent works [20, 41], sequence-based models seem to outperform graph-based ones. Meanwhile, recently large language models (especially ChatGPT) have attracted much attention since their powerful ability can be easily adapted to various types of downstream tasks, including vulnerability detection. However, there are no comparisons between ChatGPT and existing models. Considering these issues, we want to conduct an extensive study to comprehensively compare learning-based models' abilities.

Experimental Setup. We consider three graph-based approaches (i.e., Devign [63], REVEAL [12] and IVDetect [26]) and two sequence-based approaches (i.e., LineVul [20] and SVulD [41]). Meanwhile, to comprehensively compare the performance difference, we adopt the currently largest dataset MageVul. Since graph-based approaches usually need to obtain the structure information of the function (e.g., CFG, DFG), we adopt the same toolkit with Joern to transform functions and drop the fail-passed cases. Finally, the filtered dataset (391,401, shown in Table 2) is used for evaluation and we follow previous work [20, 40] to split the dataset into the training data (i.e., 80%), validating data (i.e., 10%), and testing data (i.e., 10%). We also keep the distribution as same as the original ones in training, validating, and testing data.

Furthermore, we also consider another LLM model ChatGPT and it also treats source code as a sequence of tokens. We prompt ChatGPT with an in-context learning setting and equip it with 1~6 examples selected from the same projects (i.e., cf. Section 3.1 for details). ChatGPT is a commercial conversation-based LLM model developed by OpenAI and can only be accessed by its API or web interface. Considering the large-scale testing size (i.e., 38,749 functions) as well as the substantial cost when interacting with ChatGPT, we follow previous work [14] to statistically sample some cases with 95% confidence and we conduct experiments on these sampled functions.

Table 3: The comparisons among learning-based approaches

Types	Models	Accuracy	Recall	Precision	F1
Graph Based	Devign	0.742	0.622	0.068	0.122
	Reveal	0.780	0.545	0.070	0.125
	IVDetect	0.792	0.582	0.080	0.141
Sequence Based	LineVul	0.962	0.593	0.117	0.195
	SVulD	0.822	0.637	0.100	0.172
	ChatGPT*	0.932 ± 0.015	0.125 ± 0.020	0.057 ± 0.014	0.078 ± 0.016

* Notice that the performance of ChatGPT is calculated on statistical sampling with 95% confidence.

Results. Table 3 shows the comparison results and the best ones are highlighted in bold. From the results, we can draw the following observations: (1) Surprisingly, the sequence-based modes perform better than the graph-based models in terms of all evaluated metrics, which indicates that we may not be concerned about the complex code structure when utilizing deep learning techniques to build a vulnerability detector. (2) Among sequence-based models, these methods have a complementary ability to detect vulnerabilities. More precisely, LineVul performs better in terms of *Accuracy*, *Precision*, and *F1-score*, while SVulD performs better in terms of *Recall*. It means that sequence-based models can be used for different usage scenarios, for example, LineVul for high *Precision* and SVulD for high *Recall*. (3) Though ChatGPT's performance is obtained on the

statistically sampled dataset with 95% confidence, its performance is still far away from the existing SOTA baselines, especially in terms of *Recall*, *Accuracy* and *F1-score*, which means that currently, ChatGPT is not yet competent for vulnerability detection tasks. (4) Considering the original goal difference between ChatGPT (i.e., target various tasks including QA, NLP, SE, etc.) and existing sequence models (i.e., LineVul and SVulD, target exclusively vulnerability detection), we find that it is necessary to build a vulnerability detection targeted model to make further progress in the field.

Finding 1: (1) *Sequence-based vulnerability detection models achieve better performance than graph-based models.* (2) *ChatGPT is not yet competent for software vulnerability detection and it is necessary to build a vulnerability detection targeted sequence model.*

• [RQ-2]: What types of vulnerabilities are learning-based approaches skilled in detecting?

Objective. Many types of models have been proposed for vulnerability detection and among them, graph-based and sequence-based are the promising ones. However, different approaches may have their own advantages in detecting different types of vulnerabilities. Figuring out their expertise can better guide us in practical usage. Therefore, we want to analyze what are the types of vulnerabilities that each learning-based approach skilled in.

Experimental Setup. We make an analysis of each approach's performance on vulnerability types in the testing dataset and pick up the Top-10 vulnerability types that are most correctly classified for each method. Besides, following previous work [51], we can group the vulnerabilities into 7 categories, namely *Input Validation and Representation*, *API Abuse*, *Security Features*, *Time and State*, *Errors*, *Code Quality*, and *Encapsulation*, shown under vulnerability types in Table 4. Specifically, "Input Validation and Representation" is caused by metacharacters, alternate encodings, and numeric representations. e.g., CWE-787 "Out-of-bounds Write". The mapping of the complete CWE list to these groups can be found in our dataset. "API Abuse" is commonly caused by the caller failing to honor the end of a contract between the caller and callee, e.g., CWE-252 "Unchecked Return Value". "Security Features" mainly concerns topics like authentication, access control, confidentiality, cryptography, and privilege management, e.g., CWE 359 "Privacy Violation". "Time and State" mainly concerns the time and state in distributed computation for more than one component to communicate correctly by sharing the state and time, e.g., CWE-833 "Deadlock". "Errors" relates to a class of API that handles errors, e.g., CWE-1069 "Empty Exception Block". "Code Quality" mainly concerns the unpredictable behavior caused by poor code quality. It leads to poor usability for a user and provides an opportunity to stress the system in unexpected ways for an attacker, e.g., CWE-476 "NULL Pointer Dereference". "Encapsulation" aims to draw strong boundaries of operations, e.g., CWE-501 "Trust Boundary Violation". Notice that there are no instances in *Encapsulation* and no method can correctly detect vulnerability belonging to both "Errors" and "Time and State", we do not need to analyze them further.

Table 4: Seven Types of Vulnerability

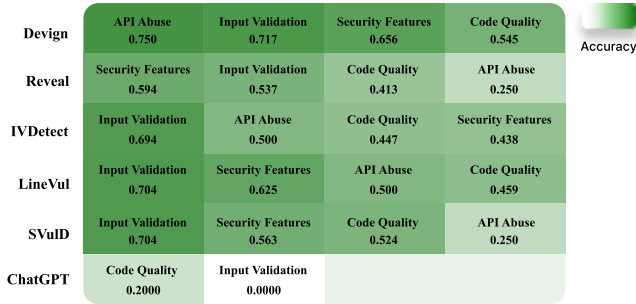
Vulnerability Type	# Total	# Testing	CWE Example
Input Validation and Representation	2,887	294	CWE-20
Code Quality	1,543	170	CWE-416
Security Features	376	32	CWE-284
API Abuse	17	4	CWE-252
Time and State	13	1	CWE-367
Errors	7	1	CWE-388
Encapsulation	-	-	CWE-501

*No C/C++ instance in MegaVul belongs to "Encapsulation".

Besides, we also analyze the Top-25 Most Dangerous Software Weaknesses¹ to figure out the promising approach in detecting the most dangerous vulnerabilities in practice. Notice that six of the most dangerous CWEs (i.e., CWE-352, CWE-434, CWE-502, CWE-77, CWE-798, and CWE-306) are not included in the testing dataset, we, therefore, delete them from the list. All the results are from the ones in RQ-1.

Table 5: Top-10 correctly detected CWE by each method

Approach	Top-1	Top-2	Top-3	Top-4	Top-5
Devign	CWE-78 [2/2]	CWE-918 [2/2]	CWE-276 [2/2]	CWE-863 [3/4]	CWE-94 [3/4]
Reveal	CWE-94 [4/4]	CWE-79 [2/2]	CWE-918 [2/2]	CWE-89 [1/1]	CWE-287 [3/4]
IVDetect	CWE-89 [1/1]	CWE-863 [3/4]	CWE-94 [3/4]	CWE-20 [61/86]	CWE-119 [104/148]
LineVul	CWE-918 [2/2]	CWE-89 [1/1]	CWE-863 [3/4]	CWE-20 [63/86]	CWE-119 [107/148]
SVulD	CWE-79 [2/2]	CWE-918 [2/2]	CWE-190 [29/35]	CWE-787 [65/79]	CWE-863 [3/4]
ChatGPT	CWE-476 [1/3]	CWE-125 [1/3]	CWE-787 [1/5]	/	/
Approach	Top-6	Top-7	Top-8	Top-9	Top-10
Devign	CWE-269 [3/4]	CWE-287 [3/4]	CWE-787 [58/79]	CWE-125 [47/70]	CWE-190 [23/35]
Reveal	CWE-787 [56/79]	CWE-20 [53/86]	CWE-190 [21/35]	CWE-125 [41/70]	CWE-119 [85/148]
IVDetect	CWE-787 [53/79]	CWE-190 [23/35]	CWE-125 [41/70]	CWE-476 [33/62]	CWE-362 [22/43]
LineVul	CWE-787 [56/79]	CWE-190 [23/35]	CWE-125 [44/70]	CWE-22 [4/7]	CWE-362 [24/43]
SVulD	CWE-287 [3/4]	CWE-119 [104/148]	CWE-20 [59/86]	CWE-362 [28/43]	CWE-125 [42/70]
ChatGPT	/	/	/	/	/

**Figure 1: Performance on Vulnerability Type**

Results. Table 5 shows the results of the Top 10 CWE that each method performs well and Fig. 1 shows the performance of different vulnerability groups. From the results, we observe that: (1) Each method performs variously on different vulnerability types which indicates their complementary ability. (2) Overall, all methods perform best in "Input Validation and Representation" and perform relatively worst in "API Abuse". (3) Sequence-based approaches perform similarly, but graph-based approaches perform differently. (4) ChatGPT performs poorly in all studied types of vulnerabilities.

Table 6 shows the performance difference of each method on Top-25 most dangerous CWE. By observing these results, we conclude that: (1) Overall, sequence-based methods perform better,

¹https://cwe.mitre.org/top25/archive/2023/2023_top25_list.html

Table 6: The performance comparison among studied six approaches on Top-25 most risk CWE

ID	CWE	Graph-based			Sequence-based		
		Devign	Reveal	IVdetect	LineVul	SVulD	ChatGPT*
1	CWE-787	53/79	41/79	53/79	56/79	67/79	1/5
2	CWE-79	2/2	1/2	0/2	1/2	1/2	0/0
3	CWE-89	1/1	1/1	1/1	1/1	0/1	0/0
4	CWE-416	34/72	26/72	26/72	31/72	35/72	0/2
5	CWE-78	0/2	0/2	0/2	1/2	1/2	0/0
6	CWE-20	56/86	43/86	61/86	63/86	61/86	0/4
7	CWE-125	47/70	41/70	41/70	44/70	41/70	1/3
8	CWE-22	5/7	4/7	3/7	4/7	4/7	0/0
11	CWE-862	0/1	0/1	0/1	0/1	0/1	0/0
12	CWE-476	34/62	27/62	33/62	30/62	37/62	1/3
13	CWE-287	3/4	4/4	2/4	2/4	3/4	0/0
14	CWE-190	27/35	23/35	23/35	23/35	29/35	0/1
17	CWE-119	100/148	70/148	105/148	107/148	103/148	0/0
19	CWE-918	2/2	0/2	1/2	2/2	2/2	0/0
21	CWE-362	24/43	16/43	22/43	24/43	24/43	0/0
22	CWE-269	3/4	2/4	2/4	1/4	2/4	0/0
23	CWE-94	3/4	2/4	3/4	0/4	2/4	0/0
24	CWE-863	1/4	1/4	3/4	3/4	3/4	0/0
25	CWE-276	2/2	0/2	1/2	1/2	0/2	0/0
# Wins (628)		397	302	380	394	415	3/18

* Notice that the performance of ChatGPT is calculated on statistical sampling with 95% confidence.

especially SVulD, which shows their potentiality in practical usage. (2) As for graph-based models, Devign (i.e., 397) outperforms Reveal (i.e., 30) and IVDetect (i.e., 380) with an improvement of 95 and 17 functions correctly classified, respectively. As for the Top 5 dangerous CWEs, Devign also performs better, which shows the priority among other graph-based models. (3) As for sequence-based models, SVulD (i.e., 415) performs best and improves LineVul (i.e., 394) by 21. The powerful ability of SVulD is also consistent in the results of Top-5 dangerous CWEs.

Finding 2: (1) Different models have their own advantages in detecting different types of vulnerabilities. Particularly, sequence-based models are skilled in "Input Validation", but graph-based models have a wide range ("API Abuse", "Input Validation" and "Security Features"). (2) Generally, sequence-based models especially SVulD perform better and SVulD shows its promising potentiality in practical usage when detecting the most dangerous vulnerabilities.

• [RQ-3]: Are Large Language Models capable of detecting vulnerabilities?

Objective. Large Language Models (LLMs) [10] have been widely adopted since the advances in Natural Language Processing (NLP) which enable LLM to be well-trained with both billions of parameters and billions of training samples, and consequently brings a large performance improvement on various tasks. LLMs can be easily used for a downstream task by being prompted [33] and they can capture different knowledge from various domain data. Previous studies [32, 34] have shown that the strength of LLMs may vary widely depending on the prompts. Therefore, we aim to investigate how LLMs perform in detecting vulnerabilities across different prompt settings since no study has been conducted comprehensively on this topic.

Experimental Setup. We conduct experiments with the state-of-the-art LLM, ChatGPT [42]. Besides, considering the consumption of interaction with ChatGPT caused by the large-scale dataset (i.e., 38,749 functions), we statistically sample from the testing dataset as suggested by previous work [14], which can also reflect the target dataset as precise as possible. In particular, we sample the instances with 95% confidence and 3% interval². Eventually, we obtain 1,039 instances to conduct our study.

Meanwhile, considering that different prompts will affect the performance of ChatGPT in vulnerability detection, we adopt three prompt settings for our study: (1) **Zero-Shot**: which directly prompts ChatGPT to detect vulnerabilities without providing any demonstrations, (2) **In-Context-Learning (ICL)**: enables ChatGPT to directly generate an answer for vulnerability detection task by feeding a few prompted demonstrations (i.e. a few shots) as part of the input, and (3) **Chain-of-Thought (CoT)**: prompts ChatGPT to achieve an answer after a step-by-step process, which largely improves performance on reasoning. Studies have shown that CoT reasoning can be performed with zero-shot prompting (Zero-Shot CoT) [24] or few-shot demonstrations (Few-Shot CoT) [57]. We consider five distinct strategies for selecting demonstrations to explore the influence of different demonstrations on Few-shot ICL and Few-shot CoT. The details of five selection strategies are elaborated as follows.

- **Fixed Selection.** We select pre-set fixed demonstrations in a sequential order from up to six CWEs (i.e., CWE-416, CWE-476, CWE-79, CWE-200, CWE-20 and CWE-787) until limitation are reached. These CWEs are selected from the Top-25 Most Dangerous Software Weaknesses.
- **Random Selection.** We randomly select a few demonstrations from training data (i.e., cf. Section 3.1 for details).
- **Random_{repo} Selection.** We randomly select demonstrations from training data and these demonstrations are from the same projects that the target function belongs to.
- **Diversity-based Selection.** We adopt a pre-trained model (i.e., CodeBERT [18]) to embed all the functions from training data and then uses K-means algorithm [35] for clustering with six centers. The demonstrations that are closest to each cluster center are selected to ensure diversity.
- **Semantic-based Selection.** We utilize CodeBERT to embed all the functions from the training data as well as the target function. Subsequently, we select the most semantically similar demonstrations to the target function based on cosine similarity.

Fig. 2 presents examples of prompt templates under three different prompt settings. These prompt templates start with the instruction "I want you to act as a vulnerability detector. Your objective is to detect... Output 'yes' if the function is vulnerable..." which explicitly states the task to be completed by the LLM and the expected output format. If the prompt includes additional demonstrations (i.e., in few-shot setting), "I will give you several examples..." will also be inserted into the instruction to explicitly indicate to the LLM the presence of multiple functions and

their vulnerability detection results within the prompt. In the few-shot setting, we employ the effective and efficient selection strategy mentioned above to choose as many demonstrations as possible from the training set until we reach the LLM's maximum input window token limitation (i.e., 4,096). Including more demonstrations in the prompt can convey task-specific knowledge to LLMs through the correlation between input and output [37], thus enhancing LLM performance. More specifically, in the ICL setting, we employ five selection strategies. For CoT, we manually craft the reasoning process for each demonstration, and hand-crafted reasoning is superior to LLM-generated reasoning [24]. Therefore, we only consider the Few-Shot setting combined with two selection strategies (i.e., Fixed Selection and Diversity-based Selection). In the Zero-Shot CoT setting, we use "Let's think by think" to prompt the LLM to generate its own reasoning process. These demonstrations and reasonings are incorporated into the prompt in a specific format, as denoted by the gray background in the figure. Subsequently, the function to be detected for vulnerabilities is added to the end of the template, forming the resulting prompt that instructs LLM to produce the final detection result.

Overall, we explore nine prompt designs for ChatGPT when detecting vulnerability and the details of the setting are illustrated in Table 7.

Results. Table 7 shows the comparison results among different prompt designs for ChatGPT when detecting vulnerability. From the detailed results, we can achieve the following observations: (1) Different prompt setting results in varying performances and no one setting can achieve the best performs for all metrics. (2) Overall, the combination of CoT and Diversity-based Selection achieved the best performance in terms of *Recall* (i.e., 0.375), improving other setting a lot (i.e., ≤ 0.125). (3) ChatGPT prompted with in-context learning as well as *Random_{repo}* strategy performance well in term of *Precision* (i.e., 0.057) and *F1* (i.e., 0.078) and also achieve a performance of *Recall* (i.e., 0.125). It seems to indicate that demonstrations from some domain with target function may help ChatGPT better to address the similar task. (4) Though "Zero-Shot" achieves best in terms of *Accuracy*, it fully performs worst in terms of other three metrics. We further analyze and find that in this setting, ChatGPT almost predicts all function as a clean one, It seems to has no ability to distinguish between clean and vulnerable ones, which is also confirmed by its performance on other three performance metrics. (5) Considering the highly imbalanced dataset in practice (i.e., 3.6% vulnerability in our dataset), ChatGPT prompted with in-context learning as well as *Random_{repo}* strategy is the best setting.

Finding 3: (1) ChatGPT has limited ability to be directly used to detect the vulnerability and different prompt designs will highly affect its performance. (2) Overall, ChatGPT prompted with in-context learning as well as *Random_{repo}* selection strategy performs the best in terms of Precision and F1-score and achieves a relatively good performance in terms of Recall.

²<https://surveysystem.com/sscalc.htm>

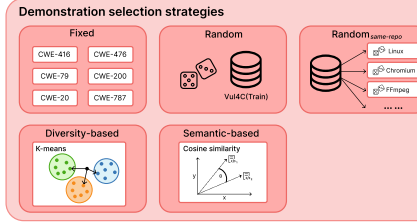
Zero-Shot

I want you to act as a vulnerability detector, your objective is to detect if a function is vulnerable. I will give you a function, you should analyze its code for potential security vulnerabilities, such as input validation issues, buffer overflow vulnerabilities, SQL injection vulnerabilities, and other security risks. Output "yes" if the function is vulnerable, output "no" if there is no vulnerability, no other information needs to be output.

```
# function
static int kvm_vm_ioctl_reinject(struct kvm *kvm,
... ..
}

# vulnerable:

```



In-Context Learning

I want ... I will give you several examples, each containing a function and an answer corresponding to whether there is a vulnerability. ... , Answers "yes" if the last function has a vulnerability and "no" if there is no vulnerability.

```
# function
static int r128_cce_blit(struct drm_device *dev,
... ..
}
# vulnerable:
yes

...

# function
void set_nlink(struct inode *inode, unsigned int nlink)
... ..
}
# vulnerable:
no

# function
static int kvm_vm_ioctl_reinject(struct kvm *kvm,
... ..
}
# vulnerable:

```

Chain-of-Thought

I want you to act as a vulnerability detector, your objective is to detect if a function is vulnerable. I will give you a function, ... Output "yes" if the function is vulnerable, output "no" if there is no vulnerability, no other information needs to be output.

```
# function
static int kvm_vm_ioctl_reinject(struct kvm *kvm,
return 0;
}

# vulnerable:

```

Let's think step by step first

Sure, let's analyze the provided function for potential security vulnerabilities step by step:

1. First, we need to understand the context of the function. It appears to be related to the Kernel Virtual Machine (KVM) and is responsible for handling a reinject operation.
2. The function checks if the `kvm→arch.vpnt` pointer is null, and if it is, it returns `-EINVAL`. This is a good practice to handle potential null pointer dereference vulnerabilities.
3. ...

```
# vulnerable:

```

Zero-Shot Version

Figure 2: Vulnerability detection prompt templates used in our study

Table 7: The prompt design for ChatGPT when detecting vulnerability

Zero-Shot	In-Context Learning	Chains-of-Thoughts	Example Selection Strategy					Accuracy	Recall	Precision	F1
			Fixed	Random	Random _{repo}	Diversity	Semantic				
✓								0.977	0	0	0
	✓		✓					0.960	0.042	0.050	0.046
	✓			✓				0.934	0.042	0.021	0.028
	✓				✓			0.932	0.125	0.057	0.078
	✓					✓		0.921	0.042	0.017	0.024
	✓						✓	0.946	0.042	0.029	0.035
✓		✓						0.867	0.083	0.017	0.028
		✓	✓					0.961	0	0	0
		✓				✓		0.733	0.375	0.033	0.061

3.2 D2: Interpretation of Learning-based Models for Vulnerability Detection

• [RQ-4]: What source code information does the learning-based model focus on? Do different types of learning models agree on similar important code features?

Objective. Vulnerability detection models should help developers understand how they make their predictions (i.e., identify vulnerable code patterns). Therefore, it is meaningful to investigate whether different deep learning models make decisions based on specific types of statements and help the model better be understood. For instance, the model might pay more attention to “if” statements when detecting input validation vulnerabilities.

Additionally, different types of learning-based approaches (i.e., graph-based and sequence-based) may focus on varying types of information, and figuring out the difference of code features concerned by models can help to better improve their abilities.

Experimental Setup. To explain the types of statements the model focuses on, we need to obtain the score for each token in the source code. We employ different interpretability techniques to acquire precise scores of tokens based on the characteristics of the studied models. For graph-based models (e.g., Devign [63] and IVDetect [26]), we utilize GNNExplainer [60], which provides scores for each edge in the constructed graph, and subsequently, we calculate

the score for each node by aggregating the scores of all incoming edges. Besides, since a node may contain several tokens, we assign the score to each corresponding token. As for the Reveal, it employs a two-stage architecture consisting of a GNN for learning feature vectors and a representation model for classification. We adopt DeepLift [46] for the representation model to unveil the contribution of each neuron to the final prediction. For sequence-based models (e.g., LineVul [20] and SVuID [41]), we use the attention layer to get each tokens’ score since they are Transformer-based model [54], naturally providing reasoning behind the prediction decision [45].

After obtaining scores for each token, we can obtain the score for each line by summing up the scores of all tokens within it. For each correctly classified vulnerable function in the testing dataset, we select the top 10 lines with the highest scores and treat them as the most important code features contributing to the model’s decision. Subsequently, we utilize Tree-sitter [8] to parse 15 types of statements (shown in Table 8) within the functions and count the occurrences of each statement type among the top 10 lines.

We also apply *t*-SNE [52], a visualization technology mapping high-dimensional features into two-dimensional features, to explore the separability of studied models between vulnerable functions

Table 8: Types of Statements

Statement Type	Brief Description
If Statement	<i>if</i> keyword and condition expression
For Statement	<i>for</i> keyword, initialization, condition, iteration expression
While Statement	<i>while</i> keyword and condition expression
Jump Statement	<i>goto, break, continue</i>
Switch Statement	<i>switch</i> keyword and condition expression
Case Statement	<i>case, default</i> keyword and value expression
Return Statement	<i>return</i> keyword
Arithmetic Operation	$+$, $-$, $*$, $/$, $\%$ Binary expression
Relational Operation	$=$, $!$, $=$, $>$, $<$, $>=$, $<=$ Binary expression
Logical Operation	$\&\&$, $\ \ $ Binary expression
Bitwise Operation	$\&$, $ $, $\wedge$, $<<$, $>>$ Binary expression
Declaration Statement	variable type and name

and non-vulnerable functions. For a better illustration, we randomly select 10,000 examples from the testing dataset and extract the hidden vectors before making the final binary classification decision as the high-dimensional features for different models, e.g., the hidden vector of the [CLS] used for sequenced-based models and the hidden features of each node used for graph-based models.

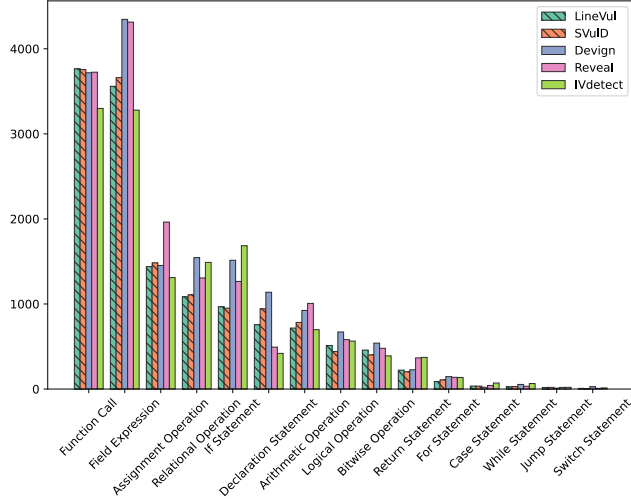


Figure 3: Number of occurrences for each statement type in the Top 10 most probable vulnerability lines. (diagonal shadow indicates sequence-base models)

Results. Fig. 3 shows the results and we obtain the following findings: (1) “Function Call” and “Field Expression” are the most risky operations identified by both graph-based and sequenced-based models. The operating frequency of the two statement types exceeds 50% among the studied 15 different statement types, which seems that both operations will introduce unstable factors to functionality and are prone to introduce vulnerabilities. For example, Fig. 4 shows a function from the Linux project that aims to parse the channel attribute in the WIFI configuration. The code (Line 21) makes a function call (i.e., “*le16_to_cpu*”) and brings a risk to the current function. That is, the external function should not be called directly for another operation, and further input validation is required to ensure the attribute has enough space to avoid “*out-of-bounds write*” vulnerability. (2) The models exhibit relatively low

attention towards “for”, “case”, “while”, “jump”, and “switch” statement types. We conducted a manual analysis of these functions and found that the statements are generally simple, making them less prone to vulnerabilities. For example, the “*while*” condition statement (Line 13 in Fig. 4) is straightforwardly presented, and developers can easily identify the termination criteria while writing the program. (3) Sequence-based models (i.e., LineVul and SVulD) perform similarly on different types of statements, possibly because both of them are built upon CodeBERT [19] and variants [21]. For example, for each type of statement, the two methods seem to achieve the same attention numbers. (4) Graph-based models pay varying attention to different types of statements. For example, for “Field Expression”, both Reveal and Devign pay more attention than IVDetect. For “Assignment Operation”, the Reveal pays more attention than both Devign and IVDetect. The difference may be caused by the way to encode the internal node among graph-based models. IVDetect strives to encode as much information as possible from a single line of code (e.g., AST, CDG, etc.) into a single node, Devign directly utilizes nodes generated by *Joern* as the nodes presented in the graph, which may explain why IVDetect shows less sensitive to the operation of accessing or operating members in *class* or *struct*, since IVDetect merges multiple field expressions into a single node, losing the detailed information, and consequently reduces its attention to such statement type.

```

1 static inline void wilc_wfi_cfg_parse_ch_attr(u8 .....
2 {
3     .....
13 while (index + sizeof(*e) ≤ len) {
14     e = (struct wilc_attr_entry *)&buf[index];
15     if (e->attr_type == IEEE80211_P2P_ATTR_CHANNEL_LIST)
16         ch_list_idx = index;
17     else if (e->attr_type == IEEE80211_P2P_ATTR_OPER_CHANNEL)
18         op_ch_idx = index;
19     if (ch_list_idx && op_ch_idx)
20         break;
21     index += le16_to_cpu(e->attr_len) + sizeof(*e);
22 }
23
24 if (ch_list_idx) {
25     .....
46 }

```

Figure 4: LineVul interpretation result(CVE-2022-47519[4])

Fig. 5 illustrates the visualization of separating vulnerable functions from non-vulnerable functions and we obtain the following observations: (1) All the figures show an overlap between the functions with or without vulnerabilities, which means that all the learning-based models have limited ability to distinguish them. By analyzing the types of statements that the models focus on (i.e., “Function Call”), it seems that the models need the context of the externally called functions to enrich the input information, which helps to better understand the functionality. (2) Sequence-based models (i.e., LineVul and SVulD) seem to have a better separation boundary (i.e., more concentrated) than graph-based models, especially LineVul seems to perform best, which is also consistent with the results obtained in RQ-1.

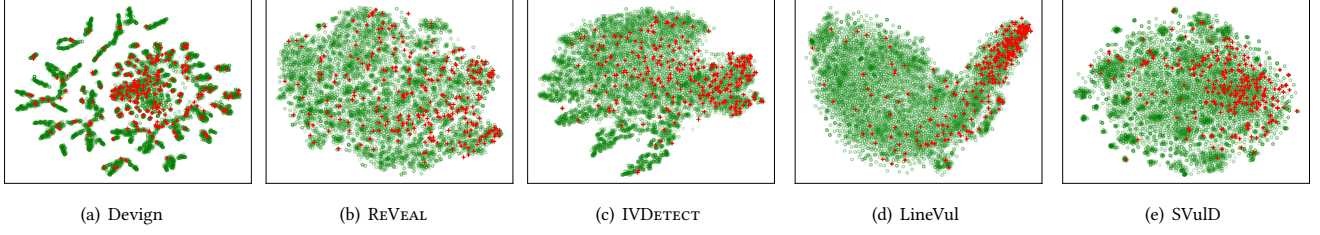


Figure 5: Visualization of the separation between vulnerable (denoted by +) and non-vulnerable (denoted by ○).

Finding 4: (1) Both graph-based and sequence-based methods technically focus on two types of statements: Function Calls and Field Expressions, which may involve vulnerable or incredible operations to functionality. (2) The existing learning-based models still have limited ability to distinguish vulnerable functions from non-vulnerable functions. Sequence-based models perform better than the graph-based models. (3) Feeding external called function information sequence-based method could further improve sequence-based models' ability.

3.3 D3: Stability of Learning-based Models for Vulnerability Detection

• [RQ-5]: Do learning-based models agree on the vulnerability detection results with themselves when the input is insignificantly changed?

Objective. An optimal vulnerability detection model should base its decisions on the root cause of vulnerabilities while demonstrating robustness against the potential impact of code layout or unrelated noise. Therefore, we want to assess the stability of the studied models by evaluating their generalizability to slightly modified but semantically equivalent input.

Experimental Setup. We apply four types of semantic-preserving transformations (introduction along with examples are shown in Table 9) to each testing sample in the original MegaVul dataset to construct four distinct variants of the test set. (1) **Remove all comments.** For each function, we remove all the comments in its source code. (2) **Insert comments.** For each function, we randomly insert single-line comments into its function body. The number of inserted comments equals 15% of the total number of lines in the function body, and the insertion positions are randomly selected. Note that the content of the comments may not be relevant to the function. (3) **Insert irrelevant code.** We randomly insert a single line of unrelated code for each function, which will not influence the function's functionality and output. (4) **Rename all identifiers.** For each function, we consistently replace the names of its parameters and variables declared within its function body with VAR0, VAR1, ..., VARX, which ensures that the program semantics and functionalities remain unchanged. Then, we test the models trained in Section 3.1 on the four variant test sets. We adopt a comprehensive performance metric F1 to analyze the performance difference.

Results. Table 10 shows the results of the studied models on the original test set and its four variants. From the results, we achieve the following observations. (1) All studied models are unstable to the

Table 9: Semantic-preserving Transformation Types

Transformation Type	Summary	Example
Remove all comments	Remove all comments from the function	<code>/* Initializing variables before the main loop. */</code>
Insert comments	Randomly insert comments into the function	<code>/* A loop to iterate over elements in an array. */</code>
Insert irrelevant code	Randomly insert unrelated code into the function	<code>if(0) {}</code>
Rename all identifiers	Replace parameters and declared variables with VARX	<code>int delta; int VAR2;</code>

Table 10: Performance difference between original MegaVul test set and its four semantically-equivalent variants

Types	Models	Original	Remove All Comments	Insert Comments	Insert Irrelevant Code	Rename All Identifiers
Graph Based	Devign	0.122	0.075 (38.8%↓)	0.075 (38.3%↓)	0.073 (40.0%↓)	0.075 (38.4%↓)
	Reveal	0.125	0.099 (20.7%↓)	0.093 (25.6%↓)	0.094 (24.5%↓)	0.097 (22.0%↓)
	IVDetect	0.141	0.051 (64.0%↓)	0.052 (63.0%↓)	0.055 (61.2%↓)	0.025 (82.5%↓)
Sequence Based	LineVul	0.195	0.196 (0.6%↑)	0.186 (4.5%↓)	0.195 (0.1%↑)	0.183 (6.3%↓)
	SVulD	0.172	0.174 (1.2%↑)	0.163 (5.4%↓)	0.179 (3.8%↑)	0.186 (7.9%↑)
	ChatGPT*	0.078	0.073 (6.0%↓)	0.068 (12.7%↓)	0.089 (13.6%↑)	0.066 (14.9%↓)

* Notice that the performance of ChatGPT is calculated on statistical sampling with 95% confidence.

four types of semantic-preserving transformations. (2) Sequence-based models achieve a relatively smaller performance change, which means that these models are more stable than graph-based models. The robustness of the sequence-based models may be explained by their elaborate and complex model architectures with large amounts of parameters and also indicates the existence of less meaningful tokens in code [61]. (3) Graph-based models suffer from a severe performance decrease. In particular, IVDetect is affected the most, whose performance drops by 61.2%~82.5%. (4) Overall, "Rename all identifiers" impacts more to models' stability than other types of transformations.

Finding 5: All the learning-based models are unstable to input changes even if these changes are semantically equivalent. Sequence-based models are more stable to subtle input changes than graph-based models.

3.4 D4: Ease of Use of Learning-based Models for Vulnerability Detection

• [RQ-6]: What types of efforts should be paid before using a model? In what scenarios can learning-based models be applied?

Objective. We want to assess the ease of use of the vulnerability detection models by examining their input requirements and model features. These aspects can offer valuable insights for practitioners who seek practical applications of these models.

Experimental Setup. We carefully document the key steps for reproducing the graph-based, sequence-based models and ChatGPT. Specifically, we verify the input requirements for each model by examining its requirement of program integrity (i.e., whether it can handle incomplete input programs), compilation (i.e., whether the input program needs to be compiled), and input size (i.e., the upper limit of input). Furthermore, during training and inference, we record for each model whether it requires fine-tuning to ensure its optimal performance, whether its source code is available, the minimum hardware requirement, the configuration difficulty, and the data privacy security level.

Results. We summarize the ease of use of the models in Table 11. From the results, we obtain the following conclusions: (1) Graph-based models require complete input programs since their inputs must be successfully parsed into graphs, while sequence-based models do not require program integrity. (2) None of the models require the input programs to be compilable. (3) ChatGPT has the largest input size ($\leq 16K$ tokens), while sequence-based models LineVul and SVulD are limited to a small input size (≤ 512 tokens). The input size of graph-based models is medium. (4) All the models, except for ChatGPT, have released their implementation code and require fine-tuning to enhance the performance, while ChatGPT is closed-source and hard to fine-tune. (5) ChatGPT is the most user-friendly method, as it can be used directly through API or on a website. Graph-based models demand small memory ($>1GB$) but require complex preprocessing steps and configurations to construct code graphs, while sequence-based models require larger memory ($>6GB$) but involve only a small amount of coding work. (6) All models, except for ChatGPT, are privacy-safe as they can be deployed on the user's own server, while ChatGPT carries a potential risk of privacy leakage.

Finding 6: Graph-based models require complete input programs and complex configurations to construct code graphs, while sequence-based models are easier to deploy. Except for ChatGPT, all current models are relatively limited by input sizes, require fine-tuning to achieve enhanced performance, and are open-source and privacy-safe. ChatGPT is the most user-friendly option regarding input requirements and model configurations, but it presents a potential risk of privacy leakage.

3.5 D5: Economy Impact of Learning-based Models for Vulnerability Detection

• [RQ-7]: What are the costs caused by models from both time and economic aspects?

Objective. Deploying vulnerability models in a real-world setting requires appropriate resource allocation to ensure high cost-effectiveness. Users are often interested in factors such as the effort required for model training and deployment, the model's processing speed for incoming requests, and the budget associated with the deployment. Therefore, in this RQ, we aim to assess the time and economic costs of the models.

Experimental Setup. We conduct experiments on a server with a uniform configuration equipped with an Intel(R) Xeon(R) Platinum 8358P CPU @ 2.60GHz, 755GB of RAM, and 10 NVIDIA GeForce RTX 3090 graphics cards. During the data preprocessing phase, we

utilize the tools Glove, Word2Vec, and Joern. Glove and Word2Vec need to train on the train set, while Joern needs to extract graph information for all functions in the dataset. We adopt the latest versions of these tools available on GitHub. We decided to perform model training and inference on a single RTX 3090 graphics card and adjust the batch size to maximize the use of the GPU memory. We execute the experiments three times and calculate the average running time results to mitigate the bias. We use the API provided by PyTorch to iteratively obtain the parameter size of the models. The inference cost of using ChatGPT is calculated according to the pricing strategy provided on the OpenAI [6] official website, and the version of ChatGPT we used is GPT-3.5 Turbo with a 4K context window. For the other deep learning models, we calculate the cost of going from preprocess data to inference whole test set on hourly pricing using AWS's g5.xlarge instance [3], which utilizes an NVIDIA A10G with similar performance to the NVIDIA 3090.

Results. The results are summarized in Table 12. Based on the results, we can obtain the following findings: (1) Graph-based models require a significant time cost for data preprocessing, sometimes exceeding the time needed for model training. IVDetect has the longest training time among graph-based models due to its complex model structure, where the input goes through multiple layers, such as TreeLSTM, GloVe, GNN, and the pooling layer. In contrast, the model architectures of Devign and Reveal are relatively simpler. In particular, Devign trains the fastest because it only adopts a single-layer GatedGraphConv. (2) Sequence-based models, especially ChatGPT, are more complex in structures with larger amounts of model parameters, which explains their longer inference time. However, sequence-based models also have advantages: they require zero data preprocessing time; LineVul and SVulD are comparable to graph-based models in training time. Though LineVul and SVulD have similar model structures (i.e., 12 transformer layers) and we set the epoch equally as 20, LineVul requires more training time because its official implementation not adopting an early stopping mechanism. (3) Among all the models, ChatGPT is the most economical option with a cost of only 0.6385\$, which shows its potential for practical usage.

Finding 7: Graph-based models need large amounts of time for data preprocessing, but they typically train and infer fast. In contrast, sequence-based models do not involve data preprocessing, with a comparable training time and longer inference time. Overall, ChatGPT is the most economical solution.

4 THREATS TO VALIDITY

Internal Validity arises from two aspects. The first one is about the uncertainty of LLM's output. Previous work has verified that LLMs are sensitive to prompts, such as the number and quality of selected examples in-context learning and chain-of-thoughts, and natural language instruction. To alleviate this threat, we explore the performance of different example strategies in RQ1 and use fixed instructions and random seeds to ensure the generated content is relatively consistent. In addition, ChatGPT is a closed-source LLM, which poses a threat to reproducibility, so the results we report may relate to a specific version of ChatGPT (i.e., GPT-3.5

Table 11: Ease of Use of Learning-based Models

Models	Input Requirements			Model Features				
	Program Integrity	Compilation	Input Size	Fine-Tuning	Code Availability	Hardware Requirement	Configuration Difficulty	Privacy
Devign	✓	✗	Medium	✓	✓	>1GB	Difficult	Safe
Reveal	✓	✗	Medium	✓	✓	>1GB	Difficult	Safe
IVDetect	✓	✗	Medium	✓	✓	>1GB	Difficult	Safe
LineVul	✗	✗	Small	✓	✓	>6GB	Medium	Safe
SVulD	✗	✗	Small	✓	✓	>6GB	Medium	Safe
ChatGPT	✗	✗	Large	✗	✗	API	Easy	Unsafe

Table 12: Time and economic costs of the models

Model	Time			Parameter	Cost
	Pre-processing	Training	Interring		
Devign	7,103s	2,836s	101s	0.97M	2.8056\$
Reveal	7,103s	5,220s	148s	1.09M	4.4378\$
IVDetect	3,563s	1,3602s	916s	1.01M	4.8821\$
LineVul	0s	13,274s	322s	124.65M	6.1712\$
SVulD	0s	6,048s	319s	125.93M	1.7792\$
ChatGPT			1,263s	175,000.00M	0.6385\$

Turbo). Another potential threat is the implementation of a graph-based vulnerability detection model. To mitigate this threat, we leverage the open-source implementations provided by previous works. In cases where the code is unavailable, we employ paired programming to ensure a close replication of the performance reported in the original paper. Furthermore, we strictly adhere to the hyperparameters reported in the original papers.

External Validity concerns the generalization of our report results. The first threat comes from the fact that we focus on vulnerability detection in C and C++ languages, many disclosed vulnerabilities in other popular languages (e.g., Java or Python) are not considered in this study. Another threat is the impact of dataset selection. To mitigate this threat, we have created the MegaVul dataset to cover most of the C/C++ vulnerabilities recorded in the NVD database since 2003, which is the largest function-level vulnerability dataset, ensuring that the evaluation results are representative and convincing.

5 RELATED WORK

Vulnerability detection (VD) has attracted much attention and many learning-based approaches have been proposed to automatically learn the vulnerability patterns from historical data [12, 16, 27–29, 31, 59, 63]. These methods can be further divided into complex graph-based ones [11, 13, 23, 55, 59, 63] and sequence-based ones [15, 20, 41, 44], and have become state-of-the-art.

Recently, a few works have conducted empirical studies on these learning-based vulnerability detection models. Chakaborthy et al. [12] investigated the issues of synthetic datasets, data duplication, and data imbalance by studying four deep learning models and then improved their model design based on their findings. Tang et al. [50] surveyed two models to investigate the best methods among neural network architectures, vector representation methods, and symbolization methods. Lin et al. [30] construct dataset including nine software projects to evaluate six neural network models' vulnerability detection ability and their generalization. Meanwhile, Ban et al. [9] evaluated six learning based models in a cross-project

setting considering three software projects. Steenhoek et al. [48] also conduct an empirical study on deep learning based vulnerability detection models with the consideration of three dimensions (i.e., model capabilities, training data, and model interpretation).

Different from these works, our work extensively studies the characteristics of learning-based VD approaches in the era of large pre-trained language models, especially focusing on ChatGPT's remarkable ability by considering five dimensions. To the best of our knowledge, our work is the first attempt to characterize the ChatGPT's ability on VD, the ease of use of models, the model economy, and types of vulnerability that models are skilled in.

6 CONCLUSION

This paper aims to comprehensively investigate the capabilities of graph-based and sequence-based learning-based models for vulnerability detection as well as their impacts. To achieve that, we first build a large-scale vulnerability dataset and then conduct several experiments focusing on five dimensions: *model capabilities*, *model interpretation*, *model stability*, *ease of use of model*, and *model economy*. The results indicate the priority of sequence-based models and the limited abilities of both LLM (ChatGPT) and graph-based models. We also investigate the performance of learning-based models on types of vulnerability and find that both sequence-based and graph-based models are skilled in "Input Validation", while graph-based models are skilled at another two: "API Abuse" and "Security Feature". We also find that all learning-based models perform inconsistently. Finally, we conclude the pre-processing and requirements for easy usage of models and obtain vital information for economically and safely practical usage of these models.

REFERENCES

- [1] 2018. Software assurance reference dataset (SARD). <https://samate.nist.gov/SARD/>.
- [2] 2022. Chatgpt: Optimizing language models for dialogue. <https://chat.openai.com>
- [3] 2024. AWS g5 instance. <https://aws.amazon.com/cn/ec2/instance-types/g5/>.
- [4] 2024. CVE-2022-47519. <https://github.com/torvalds/linux/commit/051ae669e4505abbe05165bebf6be7922de11f41>.
- [5] 2024. Hugging Face. <https://huggingface.co>
- [6] 2024. OpenAI Pricing. <https://openai.com/pricing>.
- [7] 2024. Replication. <https://figshare.com/s/bde8e41890e8179f5e5f>
- [8] 2024. Tree-sitter. <https://github.com/tree-sitter/tree-sitter>.
- [9] Xinbo Ban, Shigang Liu, Chao Chen, and Caslon Chua. 2019. A performance evaluation of deep-learned features for software vulnerability detection. *Concurrency and Computation: Practice and Experience* 31, 19 (2019), e5103.
- [10] Tom Brown, Benjamin Mann, Nick Ryder, Melanie Subbiah, Jared D Kaplan, Prafulla Dhariwal, Arvind Neelakantan, Pranav Shyam, Girish Sastry, Amanda Askell, et al. 2020. Language models are few-shot learners. *Advances in neural information processing systems* 33 (2020), 1877–1901.
- [11] Sicong Cao, Xiaobing Sun, Lili Bo, Rongxin Wu, Bin Li, and Chuanqi Tao. 2022. MVD: Memory-Related Vulnerability Detection Based on Flow-Sensitive Graph Neural Networks. *arXiv preprint arXiv:2203.02660* (2022).

- [12] Saikat Chakraborty, Rahul Krishna, Yangruibo Ding, and Baishakhi Ray. 2021. Deep learning based vulnerability detection: Are we there yet. *IEEE Transactions on Software Engineering* (2021).
- [13] Xiao Cheng, Haoyu Wang, Jiayi Hua, Guoai Xu, and Yulei Sui. 2021. Deepwukong: Statically detecting software vulnerabilities using deep graph neural network. *ACM Transactions on Software Engineering and Methodology (TOSEM)* 30, 3 (2021), 1–33.
- [14] Roland Croft, M Ali Babar, and M Mehdi Kholoosi. 2023. Data quality for software vulnerability datasets. In *2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE)*. IEEE, 121–133.
- [15] Hoa Khanh Dam, Truyen Tran, Trang Pham, Shien Wee Ng, John Grundy, and Aditya Ghose. 2017. Automatic feature learning for vulnerability prediction. *arXiv preprint arXiv:1708.02368* (2017).
- [16] Xu Duan, Jingzheng Wu, Shouling Ji, Zhiqing Rui, Tianyue Luo, Mutian Yang, and Yanjun Wu. 2019. VulSniper: Focus Your Attention to Shoot Fine-Grained Vulnerabilities. In *IJCAI*. 4665–4671.
- [17] Jiahao Fan, Yi Li, Shaohua Wang, and Tien N Nguyen. 2020. A C/C++ code vulnerability dataset with code changes and CVE summaries. In *Proceedings of the 17th International Conference on Mining Software Repositories*. 508–512.
- [18] Zhangyin Feng, Daya Guo, Duyu Tang, Nan Duan, Xiaocheng Feng, Ming Gong, Linjun Shou, Bing Qin, Ting Liu, Daxin Jiang, et al. 2020. CodeBERT: A pre-trained model for programming and natural languages. *arXiv preprint arXiv:2002.08155* (2020).
- [19] Zhangyin Feng, Daya Guo, Duyu Tang, Nan Duan, Xiaocheng Feng, Ming Gong, Linjun Shou, Bing Qin, Ting Liu, Daxin Jiang, and Ming Zhou. 2020. CodeBERT: A Pre-Trained Model for Programming and Natural Languages. In *Findings of the Association for Computational Linguistics: EMNLP 2020*. Association for Computational Linguistics, Online, 1536–1547. <https://doi.org/10.18653/v1/2020.findings-emnlp.139>
- [20] Michael Fu and Chakkrit Tantithamthavorn. 2022. LineVul: A Transformer-based Line-Level Vulnerability Prediction. (2022).
- [21] Daya Guo, Shuai Lu, Nan Duan, Yanlin Wang, Ming Zhou, and Jian Yin. 2022. UniXcoder: Unified Cross-Modal Pre-training for Code Representation. *arXiv preprint arXiv:2203.03850* (2022).
- [22] Hazim Hanif and Sergio Maffei. 2022. Vulberta: Simplified source code pre-training for vulnerability detection. In *2022 International joint conference on neural networks (IJCNN)*. IEEE, 1–8.
- [23] David Hin, Andrey Kan, Huaming Chen, and M Ali Babar. 2022. LineVD: Statement-level Vulnerability Detection using Graph Neural Networks. *arXiv preprint arXiv:2203.05181* (2022).
- [24] Takeshi Kojima, Shixiang Shane Gu, Machel Reid, Yutaka Matsuo, and Yusuke Iwasawa. 2022. Large language models are zero-shot reasoners. *Advances in neural information processing systems* 35 (2022), 22199–22213.
- [25] Bo Li, Kevin Roundy, Chris Gates, and Yevgeniy Vorobeychik. 2017. Large-scale identification of malicious singleton files. In *Proceedings of the Seventh ACM on Conference on Data and Application Security and Privacy*. 227–238.
- [26] Yi Li, Shaohua Wang, and Tien N Nguyen. 2021. Vulnerability detection with fine-grained interpretations. In *Proceedings of the 29th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 292–303.
- [27] Zhen Li, Deqing Zou, Shouhuai Xu, Zhaoxuan Chen, Yawei Zhu, and Hai Jin. 2021. Vuldelocator: a deep learning-based fine-grained vulnerability detector. *IEEE Transactions on Dependable and Secure Computing* (2021).
- [28] Zhen Li, Deqing Zou, Shouhuai Xu, Hai Jin, Yawei Zhu, and Zhaoxuan Chen. 2021. Syssev: A framework for using deep learning to detect software vulnerabilities. *IEEE Transactions on Dependable and Secure Computing* (2021).
- [29] Zhen Li, Deqing Zou, Shouhuai Xu, Xinyu Ou, Hai Jin, Sujuan Wang, Zhijun Deng, and Yuyi Zhong. 2018. Vuldeepecker: A deep learning-based system for vulnerability detection. In *Proceedings of the 25th Annual Network and Distributed System Security Symposium*.
- [30] Guanjun Lin, Wei Xiao, Leo Yu Zhang, Shang Gao, Yonghang Tai, and Jun Zhang. 2021. Deep neural-based vulnerability discovery demystified: data, model and performance. *Neural Computing and Applications* 33, 20 (2021), 13287–13300.
- [31] Guanjun Lin, Jun Zhang, Wei Luo, Lei Pan, and Yang Xiang. 2017. POSTER: Vulnerability discovery with function representation learning from unlabeled projects. In *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security*. 2539–2541.
- [32] Jiachang Liu, Dinghan Shen, Yizhe Zhang, Bill Dolan, Lawrence Carin, and Weizhu Chen. 2021. What Makes Good In-Context Examples for GPT-3? *arXiv preprint arXiv:2101.06804* (2021).
- [33] Pengfei Liu, Weizhe Yuan, Jinlan Fu, Zhengbao Jiang, Hiroaki Hayashi, and Graham Neubig. 2023. Pre-train, prompt, and predict: A systematic survey of prompting methods in natural language processing. *Comput. Surveys* 55, 9 (2023), 1–35.
- [34] Yao Lu, Max Bartolo, Alastair Moore, Sebastian Riedel, and Pontus Stenetorp. 2021. Fantastically ordered prompts and where to find them: Overcoming few-shot prompt order sensitivity. *arXiv preprint arXiv:2104.08786* (2021).
- [35] James MacQueen et al. 1967. Some methods for classification and analysis of multivariate observations. In *Proceedings of the fifth Berkeley symposium on mathematical statistics and probability*, Vol. 1. Oakland, CA, USA, 281–297.
- [36] Davide Maiorca and Battista Biggio. 2019. Digital investigation of pdf files: Unveiling traces of embedded malware. *IEEE Security & Privacy* 17, 1 (2019), 63–71.
- [37] Sewon Min, Xinxi Lyu, Ari Holtzman, Mikel Artetxe, Mike Lewis, Hannaneh Hajishirzi, and Luke Zettlemoyer. 2022. Rethinking the Role of Demonstrations: What Makes In-Context Learning Work?. In *Proceedings of the 2022 Conference on Empirical Methods in Natural Language Processing*. Association for Computational Linguistics, Abu Dhabi, United Arab Emirates, 11048–11064. <https://doi.org/10.18653/v1/2022.emnlp-main.759>
- [38] Chao Ni, Liyu Shen, Xiaohu Yang, Yan Zhu, and Shaohua Wang. 2024. MegaVul: A C/C++ Vulnerability Dataset with Comprehensive Code Representation. In *Proceedings of 21th International Conference on Mining Software Repositories (MSR)*.
- [39] Chao Ni, Wei Wang, Kaiwen Yang, Xin Xia, Kui Liu, and David Lo. 2022. The Best of Both Worlds: Integrating Semantic Features with Expert Features for Defect Prediction and Localization. In *Proceedings of the 2022 30th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. ACM, 672–683.
- [40] Chao Ni, Kaiwen Yang, Xin Xia, David Lo, Xiang Chen, and Xiaohu Yang. 2022. Defect Identification, Categorization, and Repair: Better Together. *arXiv preprint arXiv:2204.04856* (2022).
- [41] Chao Ni, Xin Yin, Kaiwen Yang, Dehai Zhao, Zhenchang Xing, and Xin Xia. 2023. Distinguishing Look-Alike Innocent and Vulnerable Code by Subtle Semantic Representation Learning and Explanation. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 1611–1622.
- [42] OpenAI. 2022. ChatGPT: Optimizing Language Models for Dialogue. (2022). <https://openai.com/blog/chatgpt/>.
- [43] Adam Paszke, Sam Gross, Francisco Massa, Adam Lerer, James Bradbury, Gregory Chanan, Trevor Killeen, Zeming Lin, Natalia Gimelshein, Luca Antiga, Alban Desmaison, Andreas Kopf, Edward Yang, Zachary DeVito, Martin Raison, Alykhan Tejani, Sasank Chilamkurthy, Benoit Steiner, Lu Fang, Junjie Bai, and Soumith Chintala. 2019. PyTorch: An Imperative Style, High-Performance Deep Learning Library. In *Advances in Neural Information Processing Systems* 32. Curran Associates, Inc., 8024–8035. <http://papers.neurips.cc/paper/9015-pytorch-an-imperative-style-high-performance-deep-learning-library.pdf>
- [44] Rebecca Russell, Louis Kim, Lei Hamilton, Tomo Lazovick, Jacob Harer, Onur Ozdemir, Paul Ellingwood, and Marc McConley. 2018. Automated vulnerability detection in source code using deep representation learning. In *2018 17th IEEE international conference on machine learning and applications (ICMLA)*. IEEE, 757–762.
- [45] Sofia Serrano and Noah A Smith. 2019. Is attention interpretable? *arXiv preprint arXiv:1906.03731* (2019).
- [46] Avanti Shrikumar, Peyton Greenside, and Anshul Kundaje. 2019. Learning Important Features Through Propagating Activation Differences. *arXiv:1704.02685 [cs.CV]*
- [47] Zihua Song, Junfeng Wang, Shengli Liu, Zhiyang Fang, Kaiyuan Yang, et al. 2022. HGvul: A code vulnerability detection method based on heterogeneous source-level intermediate representation. *Security and Communication Networks* 2022 (2022).
- [48] Benjamin Steenhoeck, Md Mahbubur Rahman, Richard Jiles, and Wei Le. 2023. An empirical study of deep learning models for vulnerability detection. In *2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE)*. IEEE, 2237–2248.
- [49] Guillermo Suarez-Tangil, Santanu Kumar Dash, Mansour Ahmadi, Johannes Kinder, Giorgio Giacinto, and Lorenzo Cavallaro. 2017. Droidsieve: Fast and accurate classification of obfuscated android malware. In *Proceedings of the seventh ACM on conference on data and application security and privacy*. 309–320.
- [50] Gaigai Tang, Lianxiao Meng, Huiqiang Wang, Shuangyin Ren, Qiang Wang, Lin Yang, and Weipeng Cao. 2020. A comparative study of neural network techniques for automatic software vulnerability detection. In *2020 International symposium on theoretical aspects of software engineering (TASE)*. IEEE, 1–8.
- [51] Katrina Tsipenyuk, Brian Chess, and Gary McGraw. 2005. Seven pernicious kingdoms: A taxonomy of software security errors. *IEEE Security & Privacy* 3, 6 (2005), 81–84.
- [52] Laurens van der Maaten and Geoffrey Hinton. 2008. Visualizing Data using t-SNE. *Journal of Machine Learning Research* 9, 86 (2008), 2579–2605. <http://jmlr.org/papers/v9/vandermaaten08a.html>
- [53] Ashish Vaswani, Noam Shazeer, Niki Parmar, Jakob Uszkoreit, Llion Jones, Aidan N Gomez, Łukasz Kaiser, and Illia Polosukhin. 2017. Attention is all you need. *Advances in neural information processing systems* 30 (2017).
- [54] Ashish Vaswani, Noam Shazeer, Niki Parmar, Jakob Uszkoreit, Llion Jones, Aidan N. Gomez, Łukasz Kaiser, and Illia Polosukhin. 2023. Attention Is All You Need. *arXiv:1706.03762 [cs.CL]*
- [55] Huanting Wang, Guixin Ye, Zhanyong Tang, Shin Hwei Tan, Songfang Huang, Dingyi Fang, Yansong Feng, Lizhong Bian, and Zheng Wang. 2020. Combining graph-based learning with automated data collection for code vulnerability

- detection. *IEEE Transactions on Information Forensics and Security* 16 (2020), 1943–1958.
- [56] Wenbo Wang, Tien N Nguyen, Shaohua Wang, Yi Li, Jiyuan Zhang, and Aashish Yadavally. 2023. DeepVD: Toward Class-Separation Features for Neural Network Vulnerability Detection. In *2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE)*. IEEE, 2249–2261.
 - [57] Jason Wei, Xuezhi Wang, Dale Schuurmans, Maarten Bosma, Ed Chi, Quoc Le, and Denny Zhou. 2022. Chain of thought prompting elicits reasoning in large language models. *arXiv preprint arXiv:2201.11903* (2022).
 - [58] Xin-Cheng Wen, Yupan Chen, Cuiyun Gao, Hongyu Zhang, Jie M. Zhang, and Qing Liao. 2023. Vulnerability Detection with Graph Simplification and Enhanced Graph Representation Learning. In *45th IEEE/ACM International Conference on Software Engineering, ICSE 2023, Melbourne, Australia, May 14–20, 2023*. IEEE, 2275–2286. <https://doi.org/10.1109/ICSE48619.2023.00191>
 - [59] Fabian Yamaguchi, Nico Golde, Daniel Arp, and Konrad Rieck. 2014. Modeling and discovering vulnerabilities with code property graphs. In *2014 IEEE Symposium on Security and Privacy*. IEEE, 590–604.
 - [60] Rex Ying, Dylan Bourgeois, Jiaxuan You, Marinka Zitnik, and Jure Leskovec. 2019. GNNExplainer: Generating Explanations for Graph Neural Networks. arXiv:1903.03894 [cs.LG]
 - [61] Zhaowei Zhang, Hongyu Zhang, Beijun Shen, and Xiaodong Gu. 2022. Diet code is healthy: Simplifying programs for pre-trained models of code. In *Proceedings of the 30th ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 1073–1084.
 - [62] Jie Zhou, Ganqu Cui, Shengding Hu, Zhengyan Zhang, Cheng Yang, Zhiyuan Liu, Lifeng Wang, Changcheng Li, and Maosong Sun. 2020. Graph neural networks: A review of methods and applications. *AI open* 1 (2020), 57–81.
 - [63] Yaqin Zhou, Shangqing Liu, Jingkai Siow, Xiaoning Du, and Yang Liu. 2019. Devign: Effective vulnerability identification by learning comprehensive program semantics via graph neural networks. In *In Proceedings of the 33rd International Conference on Neural Information Processing Systems*. 10197–10207.